GROUPE:3 (BTC1 LILLE)

PROJET AEGIS – AUDIT & SÉCURISATION

Presented by
MBAYI Davian
ADJE Kenneth
NZITA Divine
TOURE Souwoye

CONTEXTE

TechSud, une PME fictive, a subi une compromission de son système d’information. Notre mission : auditer, sécuriser et documenter leur infrastructure pour éviter une nouvelle attaque.

METHODOLOGIE

METHODOLOGIE

Etape 1 :Analyse de l’existant

Etape 2 : Identification des vulnérabilités

Etape 3 : Mise en place des contre-mesures

Etape 4 : Vérification & automatisation

Etape 5 : Rapport & soutenance

PREUVE : AUDIT INITIAL

PREUVE : AUDIT INITIAL

```
PS C:\Users\davia> nmap -sV -O 192.168.56.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 12:03 +0200
Nmap scan report for 192.168.56.10
Host is up (0.00080s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE VERSION
22/tcp  closed ssh
80/tcp  closed http
443/tcp closed https
MAC Address: 08:00:27:D2:C3:D4 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|specialized
Running: Linux 2.6.X, VMware ESX Server 3.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.11 cpe:/o:vmware:esx:3.0:2
OS details: Linux 2.6.11, Linux 2.6.18, Linux 2.6.20.6, Linux 2.6.23, Linux 2.6.39, VMware ESX Server 3.0.2
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.22 seconds
```

Lors de l’audit initial, nous avons réalisé un scan Nmap afin d’identifier les ports ouverts et les services exposés. Le résultat montre que la majorité des ports sont filtrés et que les ports 22, 80 et 443 sont fermés. Cette analyse nous a permis de confirmer l’état de la machine avant la mise en place des mesures de sécurisation.

VULNÉRABILITÉS IDENTIFIÉES

VULNÉRABILITÉS IDENTIFIÉES

1. Ports ouverts non nécessaires
2. SSH non sécurisé (port par défaut, mot de passe, root autorisé)
3. Absence de politique de sécurité
4. Aucun mécanisme anti-bruteforce
5. Logs non surveillés
6. Aucun firewall actif

.lpssi

TABLEAU DE VULNEABILITÉ

TABLEAU DE VULNEABILITÉ

Vulnérabilité	Critique	Mesure appliquée
Acces root direct	Critique	PermitRootLogin no dans sshd_config
Authentification	Elevé	PasswordAutentification no _clés ssh imposé
Aucun par feu actif	Elévé	UFW configuré-deny par défaut _ports 22/80/443 uniquement
Pas de protectio bruteforce	Elévé	Fail2ban installé et actif - jail ssh cofigurée

L'infrastructure est maintenant durcie et opérationnelle. Les recommandations suivantes visent à maintenir ce niveau de sécurité dans le temps et à assurer la conformité avec le Règlement Général sur la Protection des Données (RGPD).

SOLUTION MISE EN PLACE

SOLUTION MISE EN PLACE

Solution 1 : Durcissement

Nous avons commencé par sécuriser l'accès SSH, qui représentait l'un des points d'entrée les plus sensibles. Le port par défaut a été modifié afin de réduire l'exposition aux scans automatisés, l'authentification par mot de passe a été remplacée par une authentification par clé, et l'accès root a été désactivé. Ces mesures permettent de limiter considérablement les risques d'intrusion et d'améliorer la robustesse de l'accès distant.

Solution 2 : firewall

Ensuite, nous avons mis en place un firewall configuré selon une politique restrictive. Seuls les ports strictement nécessaires au fonctionnement du système ont été autorisés, tandis que tous les autres ont été bloqués. Cette approche réduit la surface d'attaque et empêche l'accès non autorisé à des services inutiles ou non surveillés. Le firewall constitue ainsi une première barrière essentielle contre les attaques réseau.

Solution 2 : Fail2ban

Enfin, nous avons déployé Fail2ban afin de protéger la machine contre les tentatives de brute force. Le service surveille en continu les logs SSH et bloque automatiquement les adresses IP suspectes après plusieurs tentatives échouées. Cette défense active permet de neutraliser rapidement les attaques répétées et d'ajouter une couche de sécurité dynamique au système.

CAPTURE SUR LE SLIDE SUIVANT

SOLUTION MISE EN PLACE

SOLUTION MISE EN PLACE

```
sousou@projet:~$ grep -E "PermitRootLogin|PasswordAuthentication" /etc/ssh
/sshd_config
PermitRootLogin no
PasswordAuthentication no
# PasswordAuthentication no
# the setting of "PermitRootLogin no
# PAM authentication, then enable this but set PasswordAuthentication no
sousou@projet:~$ sudo ufw status verbose
[sudo] password for sousou:
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
80/tcp                     ALLOW IN    Anywhere
443/tcp                    ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)
80/tcp (v6)                ALLOW IN    Anywhere (v6)
443/tcp (v6)               ALLOW IN    Anywhere (v6)

sousou@projet:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; prese>
     Active: active (running) since Wed 2026-04-15 15:56:24 CEST; 28min a>
       Docs: man:fail2ban(1)
   Main PID: 632 (fail2ban-server)
      Tasks: 5 (limit: 2277)
```

SCRIPT PYTHON D'AUDIT

SCRIPT PYTHON D'AUDIT

- Inventaire automatique des services
- Vérification des ports ouverts
- Export JSON/CSV
- Automatisation du contrôle de conformité

macbook — kenadmin@AEGIS-DEBIANN: ~/aegis-groupeX — ssh kenadmin@10.74.2.84 — 125×31

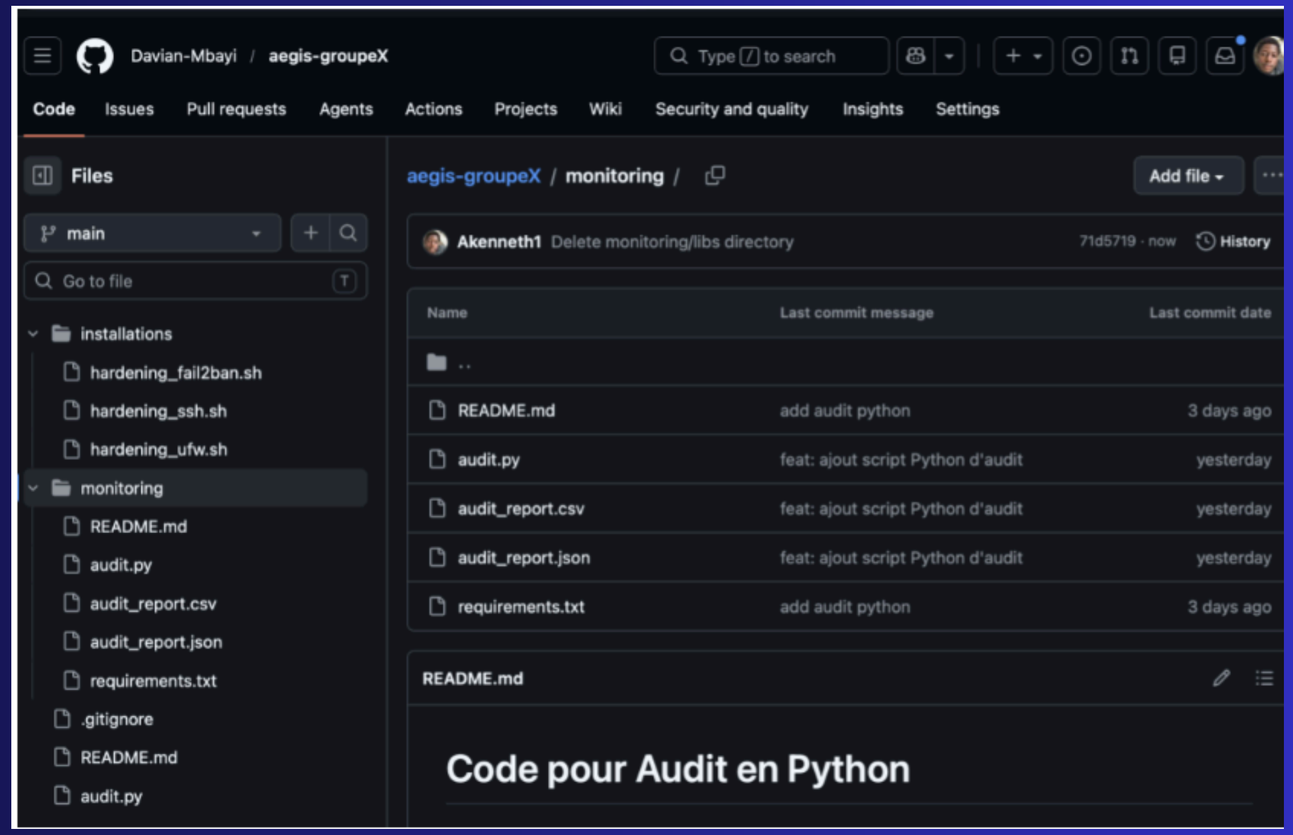
```
kenadmin@AEGIS-DEBIANN:~/aegis-groupeX$ git add monitoring/audit_report.json
kenadmin@AEGIS-DEBIANN:~/aegis-groupeX$ git commit -m "feat: ajout script Python d'audit"
[main 27e5dfc] feat: ajout script Python d'audit
 Committer: kenneth <kenadmin@AEGIS-DEBIANN.myguest.virtualbox.org>
Your name and email address were configured automatically based
on your username and hostname. Please check that they are accurate.
You can suppress this message by setting them explicitly. Run the
following command and follow the instructions in your editor to edit
your configuration file:

    git config --global --edit

After doing this, you may fix the identity used for this commit with:

    git commit --amend --reset-author

 3 files changed, 147 insertions(+)
 create mode 100644 audit.py
 create mode 100644 monitoring/audit_report.csv
 create mode 100644 monitoring/audit_report.json
kenadmin@AEGIS-DEBIANN:~/aegis-groupeX$ git push
Enter passphrase for key '/home/kenadmin/.ssh/id_ed25519':
Enumerating objects: 7, done.
Counting objects: 100% (7/7), done.
Compressing objects: 100% (5/5), done.
Writing objects: 100% (5/5), 2.88 KiB | 982.00 KiB/s, done.
Total 5 (delta 1), reused 0 (delta 0), pack-reused 0
remote: Resolving deltas: 100% (1/1), done.
To github.com:Davian-Mbayi/aegis-groupeX.git
   b0706e2..27e5dfc  main -> main
kenadmin@AEGIS-DEBIANN:~/aegis-groupeX$
```

macbook — kenadmin@AEGIS-DEBIANN: ~/aegis-groupeX/monitoring — ssh kenadmin@10.74.2.84 — 125×31

```
  GNU nano 7.2                                audit.py
#!/usr/bin/env python3
import subprocess
import json
import csv
from datetime import datetime

def run_cmd(cmd):
    try:
        return subprocess.check_output(cmd, shell=True, text=True).strip()
    except subprocess.CalledProcessError:
        return "ERROR"

def check_ssh_config():
    sshd = run_cmd("grep -E 'PermitRootLogin|PasswordAuthentication' /etc/ssh/sshd_config")
    return sshd

def check_ufw_status():
    return run_cmd("sudo ufw status verbose")

def check_fail2ban_status():
    status = run_cmd("sudo systemctl is-active fail2ban")
    jail = run_cmd("sudo fail2ban-client status sshd")
    return status, jail

def check_open_ports():
    return run_cmd("ss -tulpen")

                                   [ Read 64 lines ]
^G Help      ^O Write Out   ^W Where Is   ^K Cut       ^T Execute     ^C Location    M-U Undo      M-A Set Mark
^X Exit      ^R Read File   ^\ Replace    ^U Paste     ^J Justify     ^/ Go To Line  M-E Redo      M-6 Copy
```

ORGANISATION DU PROJET (GITHUB)

Nous avons organisé notre projet sur GitHub afin d'assurer un suivi clair et collaboratif. Le repository contient la VM, le script Python, les rapports générés et l'ensemble des fichiers nécessaires à la soutenance. Les commits réguliers permettent de tracer l'évolution du projet.



RÉSULTATS

SURFACE D'ATTAQUE RÉDUITE

SERVICES CRITIQUES SÉCURISÉS

LOGS SURVEILLÉS

INFRASTRUCTURE PLUS ROBUSTE

CONFORMITÉ AMÉLIORÉE

CONCLUSION

Ce projet nous a permis d’appliquer concrètement les notions vues en cours : audit, durcissement, scripting, RGPD et documentation. Une expérience complète et professionnalisante.

THANKS

Nous sommes prêt pour vos questions